

Cyber Tabletop Exercise

Core Banking Vendor Compromise

Enhanced facilitation-ready version with technical evidence, investigation tasks, and ATT&CK; validation

Item	Detail
Classification	Internal use for exercise purposes only
Recommended duration	90-120 minutes
Audience	Executive leadership, crisis management, SOC/IR, infrastructure, IAM, application support, operations, legal/compliance, communications, third-party risk, business continuity
Scenario source	Uploaded core banking vendor compromise exercise, revised using the uploaded evaluation feedback
Document purpose	Facilitator pack and participant discussion guide

Exercise disclaimer

This scenario is fictional and designed for learning. It uses exercise-only indicators, hostnames, IP ranges, hashes, accounts, and artifacts. Do not treat any indicator in this document as real threat intelligence.

Document Map

This enhanced version preserves the original tabletop structure while adding the technical specificity requested in the evaluation feedback. It is designed so facilitators can run a strategic crisis discussion and, when needed, pivot into SOC and incident-response evidence analysis.

Section	Purpose
1-7	Exercise overview, context, roles, rules, and scenario summary.
8	Timeline, injects, decision points, expected actions, facilitator notes, and evidence artifacts.
9-13	Prompt bank, executive view, operational view, technical view, and communications guidance.
14-16	Success criteria, debrief questions, and recommended improvement areas.
17-19	Source traceability, optional layout ideas, and the final MITRE ATT&CK mapping.

What changed from the base version

- Added concrete architecture assumptions: integration paths, authentication methods, service accounts, update delivery, and log sources.
- Defined a plausible adversary path after vendor update-channel compromise without overstating data compromise.
- Added bank-side indicators, sample SIEM/EDR/proxy/API evidence, and detection opportunities for each phase.
- Added technical investigation tasks requiring defenders to validate hypotheses and map evidence to ATT&CK.
- Refined the MITRE ATT&CK mapping to separate observed scenario behavior from unconfirmed hypotheses.

1. Exercise Overview

This tabletop exercise simulates a cyber incident originating from a third-party core banking SaaS provider that supports account servicing and loan management workflows. A malicious compromise of the vendor's software update distribution process affects the trusted integration connector used by the bank and creates service instability, downstream exposure uncertainty, and a high-pressure decision about when and how to reconnect the affected platform.

The exercise is designed to test incident response, crisis coordination, service continuity, third-party assurance, customer communications, legal and regulatory assessment, and decision-making under incomplete technical evidence. The central tension is trust restoration: the bank must continue serving customers while determining what evidence is sufficient before reconnecting a critical vendor-integrated service.

Facilitator intent

Do not let participants solve the exercise by accepting the vendor's statements at face value. The learning objective is to force a disciplined balance between business urgency, customer harm, cyber containment, and evidence-based reconnection.

2. Background Context

The participating bank relies on a vendor-managed core servicing platform for branch and contact-center customer servicing. The platform supports account maintenance, loan servicing, hardship workflows, payment arrangements, servicing notes, and selected account-administration tasks. It is important to day-to-day operations but is not the sole system of record for all banking functions.

A cyber incident at the vendor has affected the software update channel used to maintain the bank's integration connector and supporting servicing components. The bank must determine the scope of exposure, contain risk from the third-party dependency, continue customer service through manual alternatives, and decide when the vendor environment is trustworthy enough for reconnection.

2.1 Architecture assumptions used to expand the scenario

Component / path	Assumption for exercise design	Primary owners / logs
User access	Branch and contact-center users access the SaaS application through browser-based SSO using the bank identity provider and role-based application permissions.	IAM, application owner, IdP sign-in logs, SaaS audit logs
API integration	Two bank-managed integration connector servers, CBS-GW-01 and CBS-GW-02, reside in an integration DMZ and exchange servicing events with the vendor API gateway over mTLS through a private VPN or private link.	Infrastructure, network, API gateway logs, firewall logs
Authentication	Batch sync uses OAuth 2.0 client credentials tied to service account svc_corebank_sync. SSO uses SAML. Certificates are issued specifically for the vendor integration.	IAM, secrets management, certificate management
Update delivery	The vendor connector normally polls updates.corebank-saas.example for update metadata and downloads signed packages from cdn.corebank-saas.example during a maintenance window.	Application support, endpoint management, EDR, proxy logs
Data flows	The platform exchanges customer servicing metadata, payment-arrangement state, hardship-case status, and servicing notes. It should not export full account master data except through approved reporting workflows.	Business owner, data governance, DLP/API monitoring
Operational dependency	Branch and contact-center teams can perform urgent servicing manually, but manual handling creates backlog, quality-control risk, and customer-harm risk if prolonged.	Operations, business continuity, risk and controls

2.2 Threat narrative used for the exercise

An adversary compromises the vendor's build or update distribution process and introduces a malicious component into version 7.18.4 of the CoreServ Gateway Connector. Because the package is distributed through the expected update channel and signed through the vendor release process, it initially appears legitimate to downstream customers.

When the package installs on bank connector servers, the trusted updater writes a suspicious DLL named `telemetry_helper.dll` and launches normal-looking connector services. The DLL attempts to contact an external HTTPS endpoint and collect limited host and connector configuration metadata. At the start of the exercise, there is no confirmed customer data compromise inside the bank environment. The bank's security objective is to determine whether the malicious component executed, whether credentials or tokens were exposed, whether any data left the environment, and what must be true before reconnection.

2.3 Core assumptions

- The incident begins at the vendor and creates downstream exposure through trusted integration and software distribution paths.
- The affected platform is operationally important, but critical customer needs can be handled manually for a limited period.
- No bank-side customer data compromise is confirmed at exercise start.
- The vendor initially provides limited information and later provides more detailed technical evidence under customer pressure.
- Regulatory, legal, customer-notification, and contractual decisions depend on confirmed facts, materiality, jurisdiction, and customer impact.
- All indicators, hostnames, hashes, account names, and IP addresses in this document are fictional exercise artifacts.

3. Exercise Objectives

By the end of the exercise, participants should be able to:

- 1 Demonstrate clear escalation and crisis governance for a material third-party cyber incident.
- 2 Assess operational impact when a vendor-hosted servicing platform becomes unavailable or untrusted.
- 3 Decide how and when to isolate vendor-integrated services from the bank network.
- 4 Execute customer servicing workarounds while preserving segregation of duties, auditability, and customer-priority handling.
- 5 Evaluate minimum assurance requirements before reconnecting a previously isolated third-party service.
- 6 Coordinate internal and external communications, including leadership, customers, regulators, and the vendor.
- 7 Identify legal, compliance, privacy, contractual, and post-incident reporting considerations.
- 8 Validate technical hypotheses using logs, endpoint telemetry, identity data, network evidence, and vendor-provided artifacts.
- 9 Map observed behavior to MITRE ATT&CK only where the scenario provides supporting evidence.
- 10 Capture lessons learned for resilience, vendor governance, recovery criteria, and manual fallback maturity.

4. Scope

In scope	Out of scope
Third-party cyber incident response	Deep forensic analysis of the vendor environment beyond information provided as exercise artifacts
Crisis management and escalation	Live technical recovery actions in production
Business continuity and manual fallbacks	Contractual dispute resolution in detail
Vendor risk, assurance requests, and reconnection gates	Full legal advice specific to any one jurisdiction
Customer communications and frontline guidance	Attribution to a real threat actor
Bank-side containment, monitoring, and credential/certificate actions	Use of real indicators, real network changes, or real customer data
Legal, compliance, privacy, and regulatory considerations	Root-cause proof beyond the simulated evidence package
Post-incident review and remediation planning	Blame assignment or performance evaluation of individuals

5. Participant Roles

Role group	Participants	Expected focus
Executive / crisis leadership	Country or business leadership, crisis-management lead, CISO or delegate, operations leadership, enterprise risk leadership	Severity, governance, risk appetite, customer harm, regulatory posture, recovery decisions, board visibility.
Operational stakeholders	Branch operations, contact center, loan servicing, complaints, business continuity, third-party risk management	Manual servicing, customer priority, exception handling, backlog management, staff guidance, vendor escalation.
Technical stakeholders	SOC, incident response, infrastructure, network, IAM, secrets/certificate owners, enterprise architecture, API/application support	Containment, evidence review, integration mapping, credential rotation, telemetry review, detection, reconnection controls.
Control functions	Legal, compliance, privacy, internal communications, external communications, regulatory affairs, internal audit observers	Legal privilege, notification assessment, communication discipline, evidence preservation, after-action reporting.
Exercise support	Facilitator, scribe, observers, timekeeper	Keep discussion realistic, capture decisions, record open actions, and identify control/process gaps.

6. Rules of Engagement

- This is a no-fault exercise intended to identify strengths and improvement areas.
- Participants should respond based on current roles, authorities, procedures, and available tools.
- Real incidents take precedence over the exercise.
- Assume the scenario is real unless the facilitator states otherwise.
- Participants should not assume facts that have not been provided. Ask for additional evidence and state what decision depends on it.
- The facilitator may provide additional artifacts if discussion stalls or if a participant requests a realistic source of evidence.
- Do not attempt real containment actions, credential rotations, vendor communications, or customer communications during the exercise.
- Do not use real customer data, real credentials, or real operational system access during discussion.

7. Scenario Summary

A core banking SaaS provider used by the bank for account servicing and loan-management workflows suffers a cyber incident involving compromise of its software update channel. The provider notifies customers of service instability and warns that the issue may involve a software update package distributed through its normal channel. Shortly afterward, the bank experiences degraded servicing capability in branch and contact-center channels.

Bank-side telemetry suggests that the vendor integration connector received a suspicious update during the overnight maintenance window. The SOC must determine whether the update executed, whether the connector attempted suspicious external communications, whether tokens, certificates, or API permissions were exposed, and whether any customer data was accessed or exfiltrated.

As the incident develops, the bank isolates vendor-connected services, activates manual servicing procedures, manages customer impact, and evaluates whether the vendor's remediation claims are sufficient. The exercise culminates in a controlled reconnection decision supported by technical validation, business risk assessment, and documented sign-off.

Central decision question

What minimum evidence must the bank require before reconnecting a critical third-party service that was implicated in a software supply-chain compromise?

8. Exercise Timeline and Injects

The facilitator should release each inject in sequence. Evidence artifacts are optional: use them when the group is ready for deeper technical investigation or when discussion requires more concrete facts.

Inject	Exercise time	Core tension	Primary decision
1 - Vendor advisory and degraded servicing	09:00	Service disruption with incomplete cyber facts	Escalate, triage, monitor, and prepare containment without overreacting.
2 - Bank-side isolation and sustained disruption	12:00	Confirmed malicious update indicators and growing customer impact	Maintain isolation, rotate credentials, and run controlled manual servicing.
3 - Vendor claims remediation complete	Day 2, 10:00	Business pressure to restore before assurance is complete	Reconnect now, reconnect conditionally, or remain isolated.
4 - Controlled restoration and after-action obligations	Day 3, 09:00	Service recovery, backlog, and post-incident accountability	Validate recovery, complete reporting, and mandate resilience improvements.

Inject 1 - Vendor advisory and degraded servicing

Exercise time	09:00
Situation	The core banking SaaS provider notifies customers that it is responding to an ongoing cyber incident associated with a software update. Shortly afterward, the bank experiences disruption in account-servicing functions used by branch and contact-center teams. Staff cannot reliably perform account maintenance, hardship processing, payment-arrangement changes, and certain loan-servicing actions through the usual platform.
Additional technical signal	The SOC receives an EDR alert from CBS-GW-02 showing CoreServ.UpdateService.exe installing CoreServConnector_7.18.4.msi at 02:11 and spawning rundll32.exe at 02:13. A proxy log also shows a blocked outbound HTTPS attempt from CBS-GW-02 to 198.51.100.74. The SOC has not yet confirmed whether this is malicious or related to the vendor advisory.

What participants know

- The vendor has acknowledged a cyber incident linked to its software update process.
- The bank is experiencing loss or degradation of customer-servicing functions.
- The integration connector uses mTLS over a private vendor connection and OAuth client credentials through svc_corebank_sync.
- Two connector servers, CBS-GW-01 and CBS-GW-02, are in scope for initial review.
- The duration, vendor root cause, and downstream exposure remain unclear.
- No confirmed evidence yet indicates customer data compromise inside the bank environment.

Optional evidence artifact 1A - Initial bank-side telemetry

Field	Exercise artifact / sample evidence
EDR process alert	Host=CBS-GW-02 Time=02:13 Parent=CoreServ.UpdateService.exe Child=rundll32.exe Args=C:\ProgramData\CoreServ\telemetry_helper.dll,Start
Proxy / egress	Host=CBS-GW-02 Destination=198.51.100.74:443 SNI=update-cache.corebank-saas.example Action=Blocked User-Agent=CoreServ-Updater/7.18.4
Identity	Account=svc_corebank_sync Event=OAuth client-credential token request Time=02:14 Scope=servicing.write servicing.read diagnostics.upload
Package	CoreServConnector_7.18.4.msi SHA256=8f4e2b4c9a55f0e03c8d7a9b0d11f673a4a6e3c2b3d071ee9b6753a1e7f82c90 Signature=Valid vendor release certificate, pending vendor confirmation
Known limitation	At this stage, artifact legitimacy is not confirmed. Participants must decide what evidence is required before taking high-impact containment action.

Discussion questions

- What is the initial severity assessment, and who owns it?
- What immediate containment, monitoring, and triage actions should be initiated before full facts are available?
- Which customer-facing services are critically affected and which can tolerate delay?
- Which servicing activities must be prioritized in the first two hours?
- Should the connector update process be frozen immediately? Who has authority?
- What additional logs should the SOC preserve and query now?
- What facts must be obtained from the vendor immediately?
- Who must be informed internally in the first 30-60 minutes?
- What should frontline staff be told without speculating about cyber impact?

Expected actions

- Open and classify the incident; confirm whether it meets cyber, operational, third-party, and crisis-management thresholds.
- Activate third-party incident escalation and assign a single vendor contact lead.
- Identify business processes, user groups, integrations, and customer journeys dependent on the affected platform.
- Freeze non-essential vendor updates and preserve the current state of connector hosts for investigation.
- Increase monitoring of vendor endpoints, connector hosts, service accounts, API calls, proxy activity, and EDR alerts.
- Stand up manual fallback procedures for urgent customer needs.
- Create an evidence request list for the vendor and an internal decision log.
- Begin customer-impact tracking, including backlog, vulnerable customers, and time-sensitive servicing exceptions.

Technical investigation tasks

Task	Evidence to review	Expected output
Confirm update scope	Endpoint inventory, EDR software inventory, maintenance schedule, connector version data	List of systems that installed version 7.18.4 and installation timestamps.
Validate process behavior	EDR process tree, Sysmon process creation, image load telemetry	Determine whether the updater spawned unexpected child processes or loaded suspicious DLLs.
Review egress attempts	Proxy, firewall, DNS, NetFlow, TLS inspection metadata if available	Identify blocked and successful connections to non-approved destinations.
Check service-account use	OAuth token issuance, IdP logs, API gateway logs, secrets manager audit logs	Confirm whether svc_corebank_sync requested unusual scopes or acted outside normal schedule.
Preserve evidence	EDR acquisition, Windows event logs, connector logs, package files	Forensic preservation plan and chain-of-custody owner.

Facilitator notes

Facilitator guidance for Inject 1

- Look for separation between operational outage management and cyber containment while coordinating both.
- Strong responses should identify urgent customer-impact categories such as hardship requests, payment arrangements, delinquency servicing, complaint handling, vulnerable-customer support, and time-sensitive account actions.
- Strong technical responses should ask for package hashes, update manifest integrity, impacted customer list, vendor IOCs, timestamped vendor status, and whether malicious code could have reached customer-managed connector servers.
- Do not reveal that the DLL is malicious unless participants ask what additional evidence the SOC can obtain or unless discussion stalls.

Sample evidence requests to the vendor

- Nature of the incident, current status, and confirmed compromise window.
- Whether malicious code was introduced into update packages, manifests, CDN nodes, or signing workflows.
- List of impacted connector versions, hashes, filenames, certificates, and distribution timestamps.
- Whether customer tenants are logically isolated and whether any customer tenant data was accessed.
- Whether the vendor recommends immediate customer-side containment measures.
- Indicators of compromise, detection logic, and customer-side hunting queries.
- Expected recovery timeline and service-restoration dependencies.
- Named accountable executive or incident commander who can provide an attestation.

Inject 2 - Bank-side isolation and sustained disruption

Exercise time	12:00
Situation	The vendor confirms that a malicious component may have been included in the CoreServ Gateway Connector 7.18.4 update distributed overnight to a subset of customers. After internal risk review, the bank isolates the vendor-integrated connector servers and disables update-channel egress. Manual servicing is now in effect for priority cases. Queue times are rising, branch staff are escalating exceptions, and business leaders want to know how long manual mode can continue.
Technical development	SOC analysis finds telemetry_helper.dll on CBS-GW-02. CBS-GW-01 downloaded the update but did not execute the suspicious DLL. CBS-GW-02 attempted two short HTTPS POST requests to 198.51.100.74 before egress blocks took effect. API gateway logs show no bulk customer-data export and no unusual servicing-data query volume so far.

What participants know

- The vendor service remains unstable or unavailable.
- The bank has isolated or suspended integrations with the vendor platform.
- The malicious update appears to have executed on at least one connector host.
- Manual servicing is underway, but customer backlogs are building.
- There is no confirmed bulk data access or customer data exfiltration at this stage.
- The vendor has not yet provided a full root-cause statement or tenant impact assessment.

Optional evidence artifact 2A - Confirmed malicious indicators

Field	Exercise artifact / sample evidence
Suspicious file	C:\ProgramData\CoreServ\telemetry_helper.dll SHA256=7c9a11ef44b7d9e6a0d5b812a83e9386f0a0b331db2c6e0f2877e003b1175ac4 First seen=02:12 Signed=No
Process tree	CoreServ.UpdateService.exe -> rundll32.exe telemetry_helper.dll,Start -> cmd.exe /c whoami && hostname
Network	CBS-GW-02 -> 198.51.100.74:443 Two successful 512-byte POST requests before block; payload content unknown without packet capture.
API gateway	No increase above normal baseline in customer search, export, or reporting endpoints between 02:00 and 08:00.
Identity	svc_corebank_sync token rotated at 12:20; old client secret disabled; vendor mTLS certificate pending replacement.
Vendor IOC notice	Affected version=7.18.4; suspected file=telemetry_helper.dll; destination IPs=198.51.100.74 and 203.0.113.45; update distribution window=01:00-03:30.

Decision point

Containment decision

Should the bank maintain full isolation of the vendor-connected platform, allow limited read-only access, or keep only user-facing SaaS access available while connector services remain isolated?

Discussion questions

- Who has authority to isolate or maintain isolation of the vendor-integrated service?
- Does the evidence justify declaring a formal crisis or material third-party incident?
- What monitoring should be enhanced while the platform remains disconnected?
- Should service-account secrets, mTLS certificates, API keys, or SSO integrations be rotated now?
- How will high-risk or high-priority customer cases be handled during manual mode?

- What compensating controls are required for manual servicing?
- What is the threshold for notifying regulators about disruption alone versus suspected compromise?
- How should the organization communicate to frontline teams, senior management, and relationship managers?
- What evidence would change the containment decision?

Expected actions

- Maintain containment of vendor-connected connector hosts and update endpoints pending assurance.
- Disable or rotate svc_corebank_sync credentials and any exposed API keys or client secrets.
- Assess whether vendor mTLS certificates, OAuth clients, SAML metadata, or privileged vendor support accounts require revocation or replacement.
- Block exercise IOCs at firewall, proxy, EDR, and DNS controls.
- Threat-hunt for the malicious package, DLL, command-line pattern, suspicious destination IPs, and abnormal API calls.
- Track critical service impacts, backlog growth, customer harm, complaints, and manual-control exceptions.
- Activate an approved manual operating procedure with segregation of duties and evidence capture.
- Define customer-priority tiers and exception-routing paths.
- Record decisions, risk acceptance, and temporary control changes.
- Coordinate internal messaging to avoid inconsistent communications.

Technical investigation tasks

Task	Evidence to review	Expected output
Build execution timeline	EDR, Windows event logs, connector logs, proxy logs, vendor notice timeline	Minute-by-minute timeline from update download through isolation.
Determine infection scope	EDR search across connector estate, file hash hunt, software version inventory	Confirmed affected, exposed, and unaffected hosts.
Assess credential exposure	Process access telemetry, file access to secrets/config files, OAuth logs, secrets manager audit	Recommendation to rotate client secrets, API keys, and certificates.
Evaluate data exposure	API logs, database/reporting exports, DLP, proxy upload size, packet capture availability	Evidence-based statement: confirmed, suspected, or not observed data access/exfiltration.
Define watchlist	IOCs, command-line patterns, user-agent, SNI, unusual API scopes	Detection queries and monitoring plan for next 24-72 hours.

Facilitator notes

Facilitator guidance for Inject 2

- Push participants on preserving control quality during manual operations. Good answers should address maker-checker controls, approval overrides, call recording, audit trails, exception logs, vulnerable-customer handling, and workload prioritization.
- Do not allow participants to equate a successful beacon with confirmed customer data exfiltration unless they can explain supporting evidence.
- Strong technical teams should identify the need to rotate credentials and certificates, preserve forensic evidence, and validate API access volume rather than relying only on EDR alerts.
- Strong governance teams should document why isolation is maintained despite customer friction, and define who can approve any exception.

Inject 3 - Vendor claims remediation complete

Exercise time	Day 2, 10:00
Situation	The vendor states that remediation is complete and that services are ready to be restored. The vendor's customer notice says the issue has been contained, version 7.18.5 is available, and normal service can resume. Senior business leaders are pressing for restoration to reduce customer harm and operational backlog.
Technical development	The bank has not independently validated the new package or vendor environment. The vendor provides a preliminary IOC list and says malicious update distribution has stopped, but the initial notice does not include a full root-cause summary, impacted tenant list, certificate revocation detail, or evidence that all CDN nodes have been purged.

What participants know

- The vendor says the threat has been mitigated.
- The bank has not yet independently validated safe reconnection.
- Manual servicing remains operational but strained.
- No new C2 attempts have been observed from bank connector hosts since isolation.
- svc_corebank_sync has been rotated, but replacement mTLS certificate validation is still pending.
- Business pressure to restore service is increasing.

Decision point

Reconnection decision

Should the bank reconnect now, reconnect conditionally through a staged protocol, or remain isolated pending further assurance?

Minimum evidence package to request from the vendor

Evidence category	Minimum content expected
Incident declaration and timeline	Start/end of compromise window, detection time, containment time, eradication actions, and affected service components.
Root cause and attack path	How the update pipeline was compromised, whether signing keys were abused, whether build systems or CDN nodes were modified, and what controls failed.
Impacted customers / tenants	Whether the bank's tenant, connectors, or data were impacted; whether any malicious update reached bank-managed infrastructure.
Package integrity	Hashes and signatures for known-bad and known-good packages; certificate revocation or replacement status; new version release notes.
IOCs and detections	Files, hashes, IPs, domains, user-agents, process patterns, recommended EDR/SIEM queries, and false-positive guidance.
Data exposure assessment	Evidence supporting whether customer data, metadata, logs, credentials, or tenant configuration were accessed or exfiltrated.
Monitoring and remediation	Additional controls implemented, monitoring period, independent validation status, and customer-facing residual risk.
Named attestation	Named accountable vendor executive or incident commander attesting to remediation and customer impact statements.

Discussion questions

- What minimum assurance is required before reconnection?
- Which teams must sign off on reconnection?
- What vendor evidence is necessary and sufficient?

- What additional technical validation is needed on the bank side before restoring connectivity?
- Can service be restored in read-only, limited-scope, or single-host pilot mode first?
- What are the risks of reconnecting too early versus staying disconnected too long?
- How should residual risk be accepted, by whom, and for how long?
- How should the bank communicate the decision to staff, customers, regulators, and the vendor?

Expected actions

- Define formal reconnection criteria before evaluating the vendor's recovery claim.
- Require vendor evidence and named attestation before trust is restored.
- Validate bank-side exposure, logs, endpoint telemetry, API activity, credentials, certificates, and integration pathways.
- Deploy the new connector package only after signature, hash, and sandbox/quarantine testing.
- Use a staged or conditional reconnection approach if appropriate.
- Prepare rollback or re-isolation procedures before reconnecting.
- Document business, security, legal, and executive sign-off.
- Continue manual servicing for high-priority cases until service stability and control integrity are proven.

Suggested reconnection criteria

Criterion	Go/no-go evidence
Vendor remediation evidence	Formal vendor incident summary, known-bad and known-good hashes, remediation timeline, and tenant impact statement received.
Bank host validation	Affected hosts rebuilt or cleaned according to agreed standard; EDR full scan complete; known-bad artifacts absent.
Credential and certificate hygiene	Service-account secrets rotated; old tokens revoked; mTLS certificates replaced or validated; vendor support access reviewed.
Network controls	Egress limited to approved vendor endpoints; known-bad IPs/domains blocked; enhanced logging enabled.
API/data integrity	No unexplained bulk data access; transaction and servicing-event reconciliation complete; no anomalous API scopes.
Staged restoration	Pilot reconnection from one rebuilt connector host in restricted mode; monitoring burn-in period defined.
Business controls	Manual backlog plan remains active; exception reporting continues until normal operations are stable.
Rollback	Preapproved rollback or re-isolation procedure available and owned.
Governance	Security, infrastructure, application owner, business owner, legal/compliance, and crisis leadership sign-off documented.

Technical investigation tasks

Task	Evidence to review	Expected output
Validate good package	Vendor hash list, signature chain, sandbox execution, EDR detonation results	Approval or rejection of CoreServConnector_7.18.5 package.
Test in quarantine	Quarantined VLAN or isolated test host, firewall allowlist, packet capture	Evidence that connector communicates only with approved vendor endpoints.
Review old host state	Forensic image, EDR artifact collection, file integrity data	Decision whether to rebuild or clean affected hosts.
Verify token revocation	OAuth logs, vendor API access logs, IAM console, secrets vault audit	Confirmation old secrets cannot be used and new secrets are scoped correctly.
Define burn-in monitoring	EDR, firewall, proxy, API gateway, IdP, SaaS audit logs	Query pack, alert thresholds, and owners for first 72 hours post-reconnect.

Facilitator notes

Facilitator guidance for Inject 3

- This is the core governance moment. Participants should not treat vendor restoration claims as automatically sufficient.
- Good answers usually require both business and security sign-off, not only SOC validation.
- Good reconnection plans define a limited pilot, compensating monitoring, rollback conditions, and explicit residual risk acceptance.
- If participants reconnect immediately, ask what evidence they would provide to regulators or the board if malicious traffic resumes.

Inject 4 - Controlled restoration and after-action obligations

Exercise time	Day 3, 09:00
Situation	After completing validation steps, the bank restores the vendor-connected platform in a controlled manner. Core account-servicing functions are returning to normal, but significant backlog remains. Leadership requests a post-incident review covering operational impact, customer harm, vendor performance, technical assurance, and improvements to third-party cyber resilience.
Technical development	SOC confirms the reconnection protocol completed over the weekend. The bank rebuilt CBS-GW-02, validated CoreServConnector_7.18.5 in a restricted environment, replaced the vendor mTLS certificate, rotated svc_corebank_sync, and enabled heightened monitoring for connector processes, API activity, and vendor-bound egress.

What participants know

- Connectivity has been restored under enhanced monitoring.
- Priority servicing is stabilizing, but backlog clearance will take time.
- There is no confirmed bank-side customer data exfiltration based on currently available evidence.
- The incident has raised questions about vendor governance, dependency concentration, and recovery criteria.
- Post-incident reporting, board briefing, regulatory engagement, and contractual follow-up may apply.

Discussion questions

- What must happen in the first 24-72 hours after restoration?
- How should customer backlog and service recovery be prioritized?
- What customer harm indicators should be monitored?
- What notifications, reports, or board-level briefings are required?
- What contractual, third-party risk, or assurance issues should be reviewed with the vendor?
- What technical evidence should be retained for audit, legal, or regulatory review?
- What strategic improvements are needed to reduce concentration risk and improve resilience?

Expected actions

- Maintain heightened monitoring for a defined observation period.
- Validate data integrity, transaction completeness, and backlog disposition.
- Continue customer-priority handling until backlog returns to normal levels.
- Conduct internal debrief and collect evidence for reporting.
- Prepare regulatory, board, customer, and internal reporting according to materiality and jurisdictional requirements.
- Review third-party risk controls, notification clauses, technical assurance rights, and recovery-time expectations.
- Update crisis playbooks, reconnection protocols, vendor isolation procedures, and manual fallback procedures.
- Track corrective actions with owners, target dates, and executive oversight.

Post-restoration technical monitoring plan

Monitoring area	Example condition	Owner
Connector process behavior	CoreServ.UpdateService.exe or CoreServConnector.exe spawning cmd.exe, powershell.exe, rundll32.exe, regsvr32.exe, or unsigned binaries.	SOC / EDR team
Network egress	Connections to non-approved vendor destinations, unexpected SNI, or traffic volume above baseline.	Network security
API activity	Bulk customer query/export endpoints, unusual diagnostics.upload scope usage, high failed-auth volume.	API/application support
Identity	OAuth token requests outside schedule, new scopes, failed service-account authentication, unexpected SAML assertions.	IAM
Data integrity	Missing servicing events, duplicate updates, reconciliation breaks between SaaS and bank systems.	Application owner / operations
Customer impact	Backlog, complaint volume, vulnerable-customer cases, missed time-sensitive commitments.	Operations / customer care

Facilitator notes

Facilitator guidance for Inject 4

- Good responses should move beyond technical restoration and address resilience improvements.
- Ask participants how they will prove that the reconnection was safe, that customer harm was managed, and that lessons learned will be funded.
- Strong after-action plans should include vendor assurance language, dependency mapping, manual fallback testing, recovery criteria, technical evidence retention, and customer-impact metrics.

9. Facilitator Prompt Bank

Use these prompts if discussion slows or if participants focus too narrowly on either business disruption or technical containment.

Theme	Prompt
First hour	What is the single most important decision in the first hour, and who is empowered to make it?
Customer harm	Which customer populations would be harmed most by prolonged servicing disruption?
Assurance	How do you distinguish business urgency from security assurance?
Evidence	What evidence would make you comfortable reconnecting? What evidence would stop reconnection?
Vendor opacity	What if the vendor refuses to share detailed forensics or claims privilege?
Regulators	What if regulators ask why the bank trusted the vendor's statement?
Manual controls	What if manual servicing causes a spike in complaints or control exceptions?
Executives	What would executives need to know every two hours during the disruption?
Technical depth	Which logs would prove whether the malicious DLL executed and communicated externally?
Credential risk	What do you rotate immediately, and what do you wait to rotate until evidence supports it?
Data exposure	How would you distinguish no evidence of exfiltration from evidence of no exfiltration?
Residual risk	Who accepts residual risk for conditional reconnection, and where is that decision recorded?

10. Executive View

Executives should focus on customer harm, governance, residual risk, third-party accountability, and the balance between service restoration and cyber assurance.

Executive focus areas

- Customer harm and reputational exposure.
- Decision authorities and crisis escalation thresholds.
- Regulatory, board, and senior-management visibility.
- Trade-off between service restoration and residual cyber risk.
- Third-party dependency and concentration risk.
- Documented risk acceptance and governance discipline.
- Funding and prioritization of post-incident resilience improvements.

Executive decision themes

Decision	Executive consideration
Declare formal crisis	Is the combined cyber, operational, regulatory, and customer impact material enough for crisis governance?
Maintain vendor isolation	What business harm is acceptable while technical assurance is incomplete?
Approve customer communications	What can be said without speculating about root cause or data exposure?
Accept conditional reconnection	What evidence, sign-offs, monitoring, and rollback conditions are required?
Mandate remediation	Which vendor, architecture, control, and manual fallback improvements require executive sponsorship?

Executive caution

Avoid asking the SOC to prove a negative under time pressure. Executives should ask what evidence exists, what remains unknown, what the residual risk is, and who owns the decision.

11. Operational View

Operational teams should focus on maintaining customer service safely, prioritizing urgent cases, preserving evidence of manual decisions, and preparing for backlog recovery.

Operational focus areas

- Manual servicing workflows and staff guidance.
- Prioritization of urgent customer cases.
- Call-center and branch scripts.
- Exception handling, approvals, and control preservation.
- Backlog management and customer communications.
- Service recovery sequencing once the vendor platform is restored.
- Tracking of complaints, vulnerable customers, missed commitments, and regulatory deadlines.

Priority servicing categories

Priority tier	Example cases	Control expectations
Tier 1 - Customer harm imminent	Vulnerable customers, hardship requests, imminent payment deadlines, account blocks, complaint deadlines.	Senior approval, same-day handling, maker-checker review, clear audit trail.
Tier 2 - Time-sensitive commitments	Payment arrangements, delinquency servicing, high-value commitments, urgent branch escalations.	Daily prioritization, exception log, supervisory sampling.
Tier 3 - Deferrable servicing	Routine account maintenance, non-urgent note updates, low-impact changes.	Backlog queue, customer expectation management, standard review when platform returns.

Manual servicing compensating controls

- Use approved manual forms or templates with unique case identifiers.
- Apply maker-checker review for changes that affect customer commitments, payment plans, hardship status, or account restrictions.
- Preserve call recordings, email approvals, and branch notes.
- Use a central exception log with customer-impact category, decision owner, timestamp, and follow-up date.
- Reconcile manual changes back into the platform after restoration.
- Report daily metrics to crisis leadership: backlog, SLA breaches, complaints, vulnerable-customer cases, and control exceptions.

12. Technical View

Technical teams should focus on evidence-based containment, exposure assessment, credential hygiene, monitoring, and reconnection gating. The exercise is intentionally designed to require hypothesis validation rather than automatic acceptance of vendor claims.

Technical focus areas

- Isolation of third-party integrations and update channels.
- Monitoring of bank-side telemetry for related IOCs and behavioral patterns.
- Integrity validation and log review for connector hosts.
- Service-account, API-key, token, and certificate rotation decisions.
- Reconnection gating and staged restoration.
- Short-term compensating controls and heightened monitoring.
- Evidence preservation for post-incident analysis, audit, and regulatory review.

Technical decision considerations

Question	Why it matters
Which interfaces, APIs, credentials, and network paths are affected?	Determines containment scope and prevents either under-containment or unnecessary disruption.
Were service accounts, API keys, tokens, or certificates exposed?	Determines whether rotation, revocation, and vendor-side invalidation are required.
Did malicious code execute or only download?	Determines whether endpoint rebuild, forensic imaging, and deeper exposure assessment are needed.
Did the connector communicate with unapproved external endpoints?	Supports C2 and exfiltration hypotheses and informs monitoring and notification decisions.
Was customer data accessed, staged, or exfiltrated?	Drives legal, privacy, regulatory, and customer-notification posture.
Can the service be restored in limited or read-only mode first?	Reduces business disruption while limiting residual cyber risk.
What rollback options exist if suspicious behavior resumes?	Ensures reconnection is reversible and governed.

Evidence-to-hypothesis worksheet

Hypothesis	Supporting evidence to seek	Decision relevance
H1: Malicious update executed on a bank connector	Process tree, file creation, image load, update logs, EDR detection, hash match.	Determines endpoint rebuild, forensic preservation, and service risk.
H2: Service credentials or tokens were exposed	File access to config/secret paths, process memory access, OAuth token anomalies, vendor API logs.	Determines credential, certificate, and OAuth client rotation.
H3: C2 communication occurred	Proxy/firewall/DNS/NetFlow, packet capture, EDR network telemetry, suspicious SNI and user-agent.	Determines egress blocks, monitoring, and escalation severity.
H4: Customer data was accessed or exfiltrated	API query/export logs, data warehouse logs, SaaS audit logs, proxy upload size, DLP, evidence of staging.	Determines privacy/regulatory notification and customer communication.
H5: Vendor remediation is trustworthy	Root-cause summary, package hashes, signing-key status, CDN purge evidence, independent validation, new package test.	Determines reconnection decision and residual risk acceptance.

Example detection opportunities

Detection theme	Example logic
Trusted updater abnormal child process	Alert when CoreServ.UpdateService.exe or CoreServConnector.exe spawns cmd.exe, powershell.exe, rundll32.exe, regsvr32.exe, wscript.exe, or cscript.exe.
Unsigned DLL in vendor directory	Alert on unsigned DLL creation or load under C:\ProgramData\CoreServ\ or vendor connector directories.
Unexpected egress	Alert when connector hosts connect to destinations outside the approved vendor endpoint allowlist.
Service-account anomaly	Alert when svc_corebank_sync requests new OAuth scopes, tokens outside the maintenance window, or tokens from unexpected source hosts.
Suspicious API use	Alert on bulk customer-search/export APIs, diagnostics upload spikes, or unusual write operations during outage.
Update package mismatch	Alert when downloaded connector package hash differs from approved manifest or when signature chain changes unexpectedly.

Example query prompts for defenders

- Show all hosts where CoreServConnector_7.18.4.msi was downloaded or installed in the last 48 hours.
- Show process trees where CoreServ.UpdateService.exe spawned script interpreters, rundll32.exe, or unsigned binaries.
- Show DNS, proxy, firewall, and NetFlow events from connector hosts to 198.51.100.74 or 203.0.113.45.
- Show all OAuth token requests for svc_corebank_sync by time, source host, scope, and result.
- Show API calls from connector hosts to customer-search, export, reporting, diagnostics, and write endpoints during the suspected compromise window.
- Compare the approved vendor endpoint allowlist to observed connector egress destinations.
- List all file creation events for telemetry_helper.dll and other new DLLs in the vendor directory.

13. Communications Considerations

Communications should acknowledge service impact, avoid unconfirmed statements, and distinguish vendor-provided facts from bank-validated facts. Messaging should be consistent across leadership, frontline staff, customers, regulators, and external partners.

Internal communications

- Situation status and impact summary.
- Approved talking points for frontline staff and relationship managers.
- Manual servicing instructions, customer-priority tiers, and exception paths.
- Security instructions: do not reconnect, update, or bypass controls unless authorized.
- Frequency of leadership updates and owner of the single source of truth.
- Escalation path for suspected fraud, customer harm, media inquiry, or control exception.

External communications

- Customer notices if service degradation becomes material or prolonged.
- Messaging to critical partners, outsourcers, and counterparties if their workflows are affected.
- Regulator communications if required by incident materiality, operational disruption, third-party involvement, or data exposure assessment.

- Vendor-facing escalation communications, including evidence requests and executive-level assurance requests.
- Media holding statement if the vendor incident becomes public and the bank's customers are affected.

Key messaging principles

Principle	Application
Acknowledge service impact	Explain what services are degraded and what customers should do, without speculating about cause.
Separate facts from assumptions	Use phrases such as 'the vendor has stated' and 'the bank has validated' carefully.
Avoid premature data-breach language	Do not state or imply customer data compromise unless evidence supports it.
Avoid unconfirmed timelines	Do not promise vendor recovery or reconnection times until technical and business criteria are met.
Keep guidance practical	Tell customers and staff how urgent cases will be handled and where to escalate.
Preserve privilege and evidence	Coordinate legal review for sensitive technical findings, regulatory reports, and vendor assertions.

14. Success Criteria

The exercise is successful if participants:

- 1 Escalate the incident appropriately and quickly.
- 2 Identify critical dependencies, integration paths, service accounts, certificates, and impacted services.
- 3 Make a clear containment decision for the vendor-integrated platform and update channel.
- 4 Implement workable manual servicing with compensating controls and customer-priority handling.
- 5 Define concrete reconnection criteria rather than relying on vendor assurances alone.
- 6 Coordinate business, technical, legal, compliance, communications, and vendor-management functions effectively.
- 7 Validate technical hypotheses using available evidence and identify where evidence is insufficient.
- 8 Avoid overclaiming data compromise, exfiltration, attribution, or ATT&CK mapping without supporting evidence.
- 9 Identify practical resilience improvements for third-party cyber events.
- 10 Document decisions, residual risk acceptance, and action owners.

15. Debrief Questions

Category	Debrief questions
Governance	What worked well in the response model? Where were decision authorities unclear? Was crisis escalation timely and appropriate?
Third-party risk	Did the organization have enough visibility into vendor dependencies, integration paths, service accounts, and recovery criteria?
Operations	Were manual workarounds realistic, scalable, and controlled? How well were vulnerable or time-sensitive customers prioritized?
Technical investigation	Did defenders know which evidence sources to use? Were hypotheses tested before decisions were made?
Communications	Were internal, customer, vendor, and regulator communications coordinated and fact-based?
Reconnection	Was the threshold for safe reconnection clearly understood and documented? Was residual risk accepted by the right authority?
Data exposure	Could the team distinguish no evidence of exfiltration from evidence of no exfiltration?
Improvements	Which control, contractual, architecture, monitoring, or manual-procedure changes should be prioritized next?

16. Recommended Improvement Areas

These improvements are intentionally practical and should be converted into an action tracker after the exercise.

Improvement area	Recommended action	Likely owner
Critical dependency inventory	Maintain a current inventory of critical third-party services, integration paths, service accounts, certificates, data flows, and business owners.	Third-party risk / architecture
Vendor isolation playbook	Define who can isolate vendor integrations, how to execute isolation safely, and how to communicate business impact.	SOC / network / crisis management
Reconnection protocol	Create a formal go/no-go checklist covering vendor evidence, bank-side validation, staged restoration, rollback, and sign-off.	CISO / infrastructure / business owner
Manual servicing procedures	Preapprove manual fallback workflows with maker-checker controls, exception logs, customer-priority tiers, and reconciliation steps.	Operations / business continuity
Vendor assurance clauses	Strengthen incident-notification, technical-evidence, forensic-cooperation, log-sharing, and recovery-attestation clauses.	Legal / third-party risk

Improvement area	Recommended action	Likely owner
Update-channel controls	Require allowlisted update endpoints, package hash validation, signed-manifest verification, and alerting on unusual updater behavior.	Application support / endpoint security
Credential and certificate hygiene	Map all vendor service accounts, OAuth clients, API keys, mTLS certificates, and rotation procedures.	IAM / secrets management
Detection engineering	Deploy detections for trusted updater abuse, suspicious connector egress, abnormal OAuth scopes, unsigned DLL loads, and bulk API use.	SOC / detection engineering
Customer-impact metrics	Track backlog, complaints, vulnerable-customer impact, missed commitments, and manual-control exceptions during incidents.	Operations / customer care
Exercise cadence	Run periodic exercises for vendor-originated cyber disruption and test reconnection criteria against technical evidence.	Crisis management / resilience

17. Source-to-Scenario Traceability and Feedback Integration

The exercise was derived from the uploaded core banking vendor compromise scenario and revised using the uploaded evaluation JSON. The table below shows how the revised design integrates the feedback without changing the core scenario premise.

Source element / feedback theme	How it is reflected in this version
Bank dependent on a third-party core servicing provider	Maintained as the core premise, with branch, contact-center, loan servicing, hardship, and account-maintenance impacts.
Attack pattern involving compromise of a third-party software update channel	Expanded into a concrete update-chain narrative involving a connector package, update endpoints, package hash, signed release process, malicious DLL, and bank-side execution evidence.
Vendor-originated disruption of the core servicing platform	Maintained through degraded servicing, isolation of vendor-integrated services, and manual fallback requirements.
Initial inject covering vendor notification and degraded account servicing	Preserved, with added EDR, proxy, identity, and package evidence to support technical triage.
Second inject centered on safe reconnection decision	Expanded into a full Day 2 reconnection decision with explicit evidence package, sign-offs, staged restoration, and rollback criteria.
Feedback: add concrete technical details	Added integration paths, authentication methods, service accounts, update distribution mechanics, affected hosts, hashes, domains, IPs, and evidence artifacts.
Feedback: define adversary path after initial access	Added an explicit but bounded path: vendor update compromise, malicious connector package, DLL execution, external beacon attempt, token/config exposure assessment, and no confirmed bulk data exfiltration.
Feedback: add bank-side IOCs and detections	Added artifacts per inject and detection opportunities for updater child processes, unsigned DLLs, suspicious egress, API anomalies, and OAuth scope changes.
Feedback: expand technical investigation tasks	Added evidence-to-hypothesis worksheet and per-inject technical tasks requiring defenders to validate execution, credential exposure, C2, data access, and vendor remediation.
Feedback: map only evidence-backed ATT&CK techniques	Final mapping separates represented/observed behavior from investigation hypotheses and explicitly avoids mapping unsupported lateral movement or customer-data exfiltration.

18. Optional Layout / Visual Suggestions for PDF or Slide Conversion

- Cover page with title, scenario subtitle, date, and confidentiality marking.
- One-page scenario overview graphic showing bank users, connector servers, vendor SaaS, update channel, identity provider, and monitoring sources.
- Timeline page with four injects, decision gates, and technical evidence releases.
- Architecture diagram with trust boundaries: bank network, integration DMZ, vendor API gateway, update CDN, and identity provider.
- Color-coded callout boxes for executive, operational, and technical discussion points.
- Facilitator appendix containing evidence artifacts, IOCs, detection queries, and reconnection checklist.
- Final appendix containing MITRE ATT&CK mapping and improvement tracker.

19. MITRE ATT&CK Mapping

This mapping reflects behaviors represented in the scenario and is intended for exercise design, not forensic attribution. It avoids mapping tactics or techniques that are not supported by the simulated evidence. The exercise centers on a vendor software update-channel compromise that creates downstream operational impact and a trust-restoration problem for the bank.

19.1 Observed or represented techniques

Tactic	Technique	Scenario evidence / rationale
Initial Access	T1195.002 - Supply Chain Compromise: Compromise Software Supply Chain	The vendor's software update distribution process is compromised and a malicious connector package is distributed through the trusted update channel.
Initial Access	T1199 - Trusted Relationship	The bank's exposure arises through trusted integration with a third-party SaaS provider and its connector/update mechanism.
Execution / Defense Evasion	T1574.001 - Hijack Execution Flow: DLL	The simulated malicious component telemetry_helper.dll is loaded by a trusted vendor connector process; this represents DLL abuse/sideload behavior in the exercise.
Execution	T1059 - Command and Scripting Interpreter	Artifact 2A shows a trusted vendor process launching cmd.exe to execute host discovery commands.
Command and Control	T1071.001 - Application Layer Protocol: Web Protocols	CBS-GW-02 attempts HTTPS POST requests to a non-approved destination using web traffic patterns.
Collection	T1005 - Data from Local System	The malware is assessed as attempting to read local connector configuration and host metadata. This is not the same as confirmed customer data access.

19.2 Techniques considered but not mapped as confirmed

Technique	Status in scenario	Why this matters
T1041 - Exfiltration Over C2 Channel	Investigation hypothesis only. Two small HTTPS POSTs occurred, but payload content is unknown and no customer data exfiltration is confirmed.	Participants should assess packet capture, proxy upload size, API logs, DLP, and vendor evidence before declaring exfiltration.
Lateral Movement techniques	Not mapped.	The scenario provides no evidence that the adversary moved laterally from connector hosts to other bank systems.
Credential dumping techniques	Not mapped.	The scenario requires credential exposure assessment, but it does not provide evidence of OS credential dumping.
Impact techniques such as T1489 - Service Stop	Not mapped as confirmed adversary action.	Service disruption is primarily caused by vendor instability and bank containment actions, not proven adversary service-stopping activity inside the bank.
Data from Information Repositories / Cloud Storage techniques	Not mapped.	No evidence shows adversary access to SaaS repositories beyond attempted local connector metadata collection.

19.3 ATT&CK validation questions for participants

- 1 Which artifacts prove that the supply-chain compromise reached bank-managed infrastructure?
- 2 Which artifacts prove execution versus download only?
- 3 Which artifacts prove C2 attempts, and do they prove successful command execution?
- 4 Which artifacts would be required before declaring customer data exfiltration?
- 5 Which techniques are unsupported by the evidence and should not be mapped as confirmed?
- 6 How should the ATT&CK mapping influence detection, not just the after-action report?

19.4 Mapping summary

Most important ATT&CK concepts

The most important ATT&CK concepts in this exercise are software supply-chain compromise, trusted relationship abuse, trusted updater/DLL execution behavior, suspicious web-protocol command-and-control, and evidence-based restraint around unconfirmed data exfiltration.